

باسمه تعالی

عادی - آنی

جناب آقای حبیبی

مدیر عامل محترم شرکت امن افزار گستر شریف

موضوع: ابلاغ و ارسال قرارداد "ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)"

با سلام

احتراماً، به پیوست یک نسخه اصل قرارداد به شماره ۱۴۰۱/۶۸۲۵۲۵ مورخ ۱۴۰۱/۰۶/۲۰ با موضوع "ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)"، به مبلغ کل ۶,۰۰۰,۰۰۰,۰۰۰ ریال در بازه زمانی ۱۴۰۱/۰۳/۰۲ لغایت ۱۴۰۲/۰۳/۰۱ مشتمل بر ۳۰ صفحه ارسال، خواهشمند است دستور فرمائید ضمن اعلام وصول نسبت به ارائه ضمانت نامه وفق ماده ۶ قرارداد مذکور اقدام لازم معمول نمایند.

اداره کل تدارکات

فرید قهرمانی

سیدمجید شجاع الدین



رونوشت :

جناب آقای رزاقی رئیس محترم اداره کل انفورماتیک برای استحضار

اقدام کننده: دایره قراردادها - تیمورتاش (تلفن داخلی ۲۱۲۰)

قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

این قرارداد بین:

الف) بانک صادرات ایران - ادارات کل تدارکات و انفورماتیک به عنوان خریدار (کارفرما) ثبت شده به شماره ۳۸۳۳ اداره ثبت شرکتها و موسسات غیرتجاری به شناسه ملی ۱۰۸۶۱۷۳۶۰۶۲ و کد اقتصادی ۴۱۱۱۱۵۵۶۹۹۶ و نمایندگی آقایان سید مجید شجاع الدین، کاوه رزاقی و سعید جمالی که اختصاراً در این قرارداد بانک نامیده می شود از یک طرف و

ب) شرکت امن افزار گستر شریف (سهامی خاص) به شناسه ملی ۱۰۱۰۲۳۳۵۰۰۴ و کد اقتصادی ۴۱۱۱۴۵۷۶۳۷۶۷ که تحت شماره ۱۹۱۵۳۴ در اداره ثبت شرکتها و موسسات غیر تجاری به ثبت رسیده به نمایندگی آقای هاشم حبیبی به سمت مدیر عامل کد ملی ۲۵۳۹۰۲۷۲۲۹ و آقای اکبر شاملو کاظمی به سمت رئیس هیات مدیره کد ملی ۳۹۳۲۷۰۸۲۳۷ دارندگان امضای مجاز و تعهدآور شرکت بموجب آگهی مندرج در روزنامه رسمی شماره ۲۲۱۸۲ مورخ ۱۴۰۰/۰۲/۲۶ که ذیلاً شرکت (پیمانکار) نامیده میشود از طرف دیگر منعقد گردید و طرفین ملزم به رعایت مفاد و مندرجات آن شدند و این قرارداد طبق مواد ۱۰ و ۲۱۹ به بعد قانون مدنی و نیز شرایط عمومی و اختصاصی پیمان بین طرفین لازم الاجرا می باشد.

ماده ۱ - موضوع قرارداد

ارزیابی امنیتی وب سایتهای اینترنتی و تست نفوذ که شامل :

کشف، گزارش و ارائه راهکار در خصوص حفره های امنیتی سرویسها و سامانه های بانک در حوزه Bsi.ir به صورت Gray Box و Black Box و انجام خدمات مشاوره ای و امنیتی موردی حسب نیاز بانک.

تبصره ۱: ارزیابی امنیتی کلیه سامانه های موبایلی بانک نیز در محدوده این قرارداد می باشد.

ماده ۲- مدت زمان قرارداد

مدت زمان قرارداد از تاریخ ۱۴۰۱/۰۳/۰۲ به مدت یکسال تعیین میگردد.

تبصره ۱: پایان پروژه منوط به اجرای کامل موضوع پروژه و تعهدات شرکت در قرارداد و ارائه مستندات کامل مربوطه و دریافت تأییدیه مدیر و ناظر پروژه در بانک می باشد.

ماده ۳- مبلغ قرارداد و نحوه پرداخت

مبلغ کل این قرارداد تا سقف ۶,۰۰۰,۰۰۰,۰۰۰ ریال (بدون احتساب مالیات بر ارزش افزوده) می باشد که پس از انجام کار با ارائه صورتحساب رسمی از سوی شرکت و اخذ تأییدیه اداره کل انفورماتیک و کسر کلیه کسورات و عوارض قانونی در وجه شرکت پرداخت می گردد .

شرکت امن افزار گستر شریف

Page 1 of 2.

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک

بنک صادرات ایران
ات مرکزی: تهران، خیابان سمیه،
اداره کل انفورماتیک

بانک صادرات ایران
اداره کل تدارکات

معاونت بر محکمات مورداً ذکر شده است
۱۳۰۱/۱۰/۱۳

- ۱- هزینه هر بار خدمات آزمون نفوذ - انجام ارزیابی امنیتی جعبه خاکستری سطح ۲ مبلغ ۲۱۸,۰۳۷,۵۰۰ ریال می باشد که پس از پایان آزمون به شرکت پرداخت میشود.
- ۲- هزینه هر بار خدمات آزمون نفوذ - انجام ارزیابی امنیتی جعبه خاکستری سطح ۱ مبلغ ۳۲۴,۵۵۶,۲۵۰ ریال می باشد که پس از پایان آزمون به شرکت پرداخت میشود.
- ۳- هزینه انجام مشاوره ی امنیت - ارائه خدمت مشاوره به ازای هر ساعت مبلغ ۳,۸۳۳,۴۶۸ ریال ارائه می باشد که با ارائه صورتحساب از سوی شرکت و اخذ تأییدیه اداره کل انفورماتیک به صورت موردی به شرکت پرداخت میگردد.
- تبصره ۱: شرکت موظف گردید نسبت به ارسال اصل نامه و تصویر صورتحساب با عنوان اداره کل انفورماتیک و نیز ارسال رونوشت نامه به همراه اصل صورتحساب عنوان اداره کل تدارکات در طول مدت زمان قرارداد اقدام نماید.
- تبصره ۲: تعریف ارزیابی امنیتی سطح ۱: موارد آزمون طبق ضمیمه شماره دو می باشد.
- تبصره ۳: تعریف ارزیابی امنیتی سطح ۲: موارد آزمون طبق ضمیمه شماره سه می باشد.

ماده ۴ - تعهدات شرکت

تعهدات عمومی

- ۴-۱ شرکت متعهد و مکلف گردید که در زمان عقد قرارداد به کلیه نیازهای کارفرما در محدوده موضوع قرارداد شناخت کافی داشته و پوشش درخواست های جاری و ضروری مطرح شده در چهارچوب قرارداد را انجام میدهد.
- ۴-۲ شرکت متعهد و مکلف گردید حداکثر ظرف مدت ۲ روز از تاریخ انعقاد قرارداد نسبت به معرفی کارشناسان و مدیر پروژه (ساختار سازمانی پروژه) به بانک باشد.
- ۴-۳ شرکت متعهد و مکلف گردید پروتکل رمزنگاری داده و اطلاعات و تمامی فایل های تولید شده در پروژه و ایمیل ها را برای انتقال اطلاعات مخصوصا گزارش آسیب پذیری ها، تدوین و ارائه نموده و پس از تأیید بانک ملزم به رعایت آن در تمام مراحل پروژه می باشد.
- ۴-۴ شرکت متعهد و مکلف گردید حداکثر مهلت شرکت جهت انجام آزمون امنیتی موردی به ازای هر سامانه، در سطح ۲ به مدت پانزده روز از زمان اعلام بانک باشد.
- ۴-۵ شرکت متعهد و مکلف گردید حداکثر مهلت شرکت جهت انجام آزمون امنیتی موردی به ازای هر سامانه، در سطح ۱ به مدت بیست روز از زمان اعلام بانک باشد.
- ۴-۶ شرکت متعهد و مکلف گردید حداکثر مهلت شرکت جهت بررسی تنظیمات امنیتی و ف به ازای هر پروفایل، به مدت بیست و پنج روز از زمان اعلام بانک باشد.
- ۴-۷ شرکت متعهد و مکلف گردید حداکثر مهلت شرکت جهت انجام ارزیابی مجدد به ازای هر سامانه، به مدت ۴ روز از زمان اعلام بانک باشد.

شرکت امن افزار گستر شریف

Page ۲ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک

بانک صادرات ایران
اداره کل انفورماتیک

بانک صادرات ایران
اداره کل تدارکات

مهراسب بر کلاکتی صورت گرفته می باشد. انجمن

۱۴۰۱/۰۶/۲۰

تاریخ:

۱۴۰۱/۶۸۲۵۲۵

شماره:

پیوست:

باسمه تعالی



بانک صادرات ایران

قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

- جلوگیری از آسیب پذیری حرکت روی دایرکتوری ها.
- کنترل دسترسی مناسب رو منابع سیستم.
- اجرای سرویس ها با کمترین مجوز لازم.
- اعطای مجوز به طور امن برای منابع بحرانی.
- حفاظت از نشستها و شناسه های آن هنگام انتقال اطلاعات بر روی شبکه.
- سیاست مناسب برای انتخاب شناسه نشست و مدیریت نشست.
- عدم ذخیره اطلاعات حساس در نشستهای پایدار.
- عدم اعتماد سرور به مکانیزمهای کنترلی در سمت کاربر.
- کنترل صحت ورودی به طور مناسب.
- جلوگیری از حملات اجرای کد جاوا اسکریپت روی کاربر.
- جلوگیری از حملات تزریق کد به پایگاه داده.
- جلوگیری از آسیب پذیری سرریز بافر.
- جلوگیری از اجرای کد از راه دور روی سیستم عامل.
- جلوگیری از آسیب پذیری جعل درخواست کاربر از سوی مهاجم.
- مدیریت خطاها و استثنائات.
- رمزنگاری داده های حساس قبل از ارسال بر روی شبکه.
- استفاده از مقادیر تصادفی غیر قابل پیش بینی و محاسبه.
- عدم ذخیره داده های حساس در سمت کاربر.
- رویدادنگاری مفهومی وقایع امنیتی در سطح برنامه کاربردی و سرویس.
- آسیب پذیری نسبت به حملات ناکارآمدسازی سرویس
- عدم استفاده از روشهای خطرناک موجود در پروتکل HTTP
- انسداد دسترسی لیست کردن فایل روی وب سرور
- جلوگیری از آسیب پذیری SSRF
- جلوگیری از آسیب پذیری LFI
- جلوگیری از آسیب پذیری RFI

شرکت امن افزار گستر شریف

Page 4 of 30

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

سمیه، ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



مستند به کارهای صورت گرفته شده است.

ن ۲۰ الف - ۰۳۰۰ ۵۰۰ ب ۹۸ ج ۱

تاریخ: ۱۴۰۱/۰۶/۲۰

شماره: ۱۴۰۱/۶۸۲۵۲۵

پیوست:

باسمه تعالی



بانک صادرات ایران

قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

- جلوگیری از حملات افزایش سطح دسترسی در لایه برنامه کاربردی
- جلوگیری از آسیب پذیری Log Injection
- جلوگیری از حملات سوء استفاده از کارکرد
- جلوگیری از حملات تزریق به Xpath
- جلوگیری از آسیب پذیری SSI
- جلوگیری از حملات تزریقات کد به LDAP
- استفاده از سیاست های امنیتی CSP
- جلوگیری از حملات تزریق و جعل محتوا سمت کاربر
- جلوگیری از آسیب پذیری افشای کامل مسیر
- جلوگیری از حملات دستکاری پروتکل HTTP
- جلوگیری از آسیب پذیری EAR
- جلوگیری از آسیب پذیری Session Fixation
- استفاده از روندهای ایمن در طول رمزنگاری و رمزگشایی اطلاعات حساس
- آسیب پذیری منجر به حملات DOS
- نصب وصله های امنیتی
- Password-Based Attacks
- جلوگیری از حملات از نوع Backdoor
- جلوگیری از حمله TCP Hijacking

تبصره ۲: لیست نهایی حملات و آسیب پذیری هایی که مورد تست و ارزیابی قرار می گیرند به همراه موارد ذیل در متدولوژی اجرای تست نفوذ و ارزیابی امنیتی پیشنهادی از سوی شرکت می باید ارائه گردد.

✓ عوامل منجر به بروز یا ایجاد هر حمله یا آسیب پذیری

✓ ابزاری که می توان با استفاده از آن حمله یا آسیب پذیری را کشف کرد و ارائه راهکارهای عملیاتی و قابل پیاده سازی.

تبصره ۳: در صورتی که در سامانه مواردی (برای مثال استفاده از کتابخانه های قدیمی آسیب پذیر) وجود داشته باشد که در زمان ارزیابی امنیتی منتج به بروز آسیب پذیری نگردد اما شامل نکات امنیتی است که عدم رعایت آنها، ممکن است

شرکت امن افزار گستر شریف

Page ۵ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

ادارات مرکزی: تهران، سیمه، ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک



موردی که باید بررسی شود

۳۰ الف - ۵۰۰ ب ۹۸ ج

در آینده باعث بروز تهدید (و نهایتاً منجر به افزایش ریسک) شود، باید این موارد به صورت توصیه های امنیتی، از جانب شرکت در گزارش مربوطه به بانک ارائه گردند.

۴-۱۳) شرکت متعهد و مکلف به انجام برنامه زمانبندی به صورت مکتوب به بانک بوده و همچنین نمایندگان مدیر و ناظر پروژه مجاز به حضور در محل انجام آزمون در هر مرحله از مراحل آن (بنا به صلاحدید بانک) می باشند .

۴-۱۴) شرکت متعهد و مکلف گردید بر حسب ضرورت و بنا به درخواست بانک ، امکان ارتباط حضوری و تلفنی با کارشناسان آن شرکت ، خصوصاً فرد تعیین شده جهت انجام پروژه تست نفوذ (مسئول پروژه) را در کلیه روزها و ساعات مدت زمان انجام آزمون بدون محدودیت در مدت زمان مکالمه با ارائه تلفن ثابت و همراه فراهم نماید. شایان ذکر است شرکت موظف به اعلام مشخصات مسئول اجرای پروژه قبل از شروع با ذکر شماره تماس (ثابت و همراه) به صورت مکتوب به بانک می باشد .

۴-۱۵) شرکت متعهد و مکلف گردید قبل از انجام تست نفوذ و ارزیابی امنیتی اطلاع رسانی در خصوص مراحل تست نفوذ از جمله روش های مورد استفاده را همراه با ارائه مستندات مناسب به مدیر و ناظر پروژه انجام داده و هر گونه عملیات را صرفاً با آگاهی و هماهنگی مدیر و ناظر پروژه انجام دهد.

۴-۱۶) شرکت متعهد و مکلف گردید در صورت نیاز و اعلام بانک ، مدت زمان قرارداد را بدون دریافت هزینه اضافی به مدت سه ماه تمدید نماید.

۴-۱۷) شرکت متعهد و مکلف گردید کلیه موارد و نتایج در حین انجام تست های برنامه ریزی شده و بعد از آن را بسیار محرمانه تلقی نموده و از افشای این اطلاعات به افراد دیگر جداً خودداری نماید.

۴-۱۸) شرکت مسئول اعمال و رفتار پرسنل خود و تادیه غرامات مربوط به حوادث ناشی از کار و خسارات ناشی از آن می باشد.

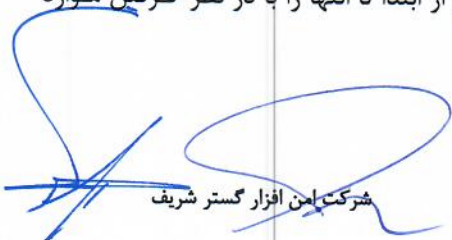
۴-۱۹) شرکت حق بارگزاری هرگونه فایل مخرب یا گرفتن دسترسی بر روی سرور سامانه را بدون اطلاع و هماهنگی و تأیید کارفرما ندارد.

۴-۲۰) شرکت حق ایجاد هرگونه تغییرات یا حذف اطلاعات مرتبط با دیگر کاربران سامانه به جز اعضای تیم معرفی شده و یا کاربران تستی مختص این قرارداد را ندارد.

۴-۲۱) شرکت متعهد و مکلف گردید هیچگونه تغییری در پیکربندی نرم افزاری هیچیک از هدفهای پروژه (از قبیل سرورها ، فایروال ها ، روترها ، کلیه تجهیزات Active و ...) ایجاد ننماید .

۴-۲۲) شرکت متعهد و مکلف گردید نسبت به انجام تست نفوذ در تمامی سامانه ها ابتدا به صورت Black Box و کشف آسیب پذیری های مربوطه و سپس به صورت Gray Box اقدام نماید. در مورد سامانه هایی که امکان ایجاد حساب کاربری در آنها توسط شرکت نمی باشد و می بایست راساً توسط بانک ایجاد شود، شرکت می بایست مراتب را جهت ایجاد حساب کاربری به بانک منعکس نماید.

۴-۲۳) شرکت متعهد و مکلف گردید، پس از پایان هر مرحله از انجام کار، کلیه گزارشها و نتایج حاصل از ارزیابی مخاطرات امنیتی آن مرحله را به همراه ارائه راهکار مناسب و موثر جهت رفع مشکل ، با فرمت مجموعه نرم افزاری Office و با بکارگیری تصاویر مربوطه ، به انضمام فیلم انجام کلیه مراحل از ابتدا تا انتها را با در نظر گرفتن موارد ذیل (شامل و نه محدود به) به بانک تحویل نماید.



شرکت امن افزار گستر شریف

- شرح کامل تمامی اقدامات و فعالیتهای انجام شده در اجرای پروژه
- شرح کامل در خصوص تجهیزات، ابزار، License ها، برنامه ها، و نرم افزارهای مورد استفاده برای اجرای پروژه همراه با دلایل استفاده از آنها.
- شرح کامل متدولوژی اجرای تست نفوذ و ارزیابی امنیتی
- گزارش کامل و تفصیلی از تمامی اقدامات صورت پذیرفته بر روی دارایی های اطلاعاتی (به تفکیک) و ابزارهای مورد استفاده به همراه خروجی های ابزارها.
- گزارش کامل و تفصیلی مخاطرات، آسیب پذیری ها و تهدیدهای امنیتی و فنی شناسایی شده به تفکیک دارایی های اطلاعاتی و دسته بندی آنها در طبقه بندی استاندارد و روش و ابزار استفاده شده برای شناسایی.
- گزارش کامل از بررسی و تحلیل آسیب پذیری ها و نقاط ضعف کشف شده.
- گزارش کامل از نتیجه گیری انجام تست نفوذ و ارزیابی امنیتی.
- ارائه زمان دقیق انجام تست هر دارایی و آسیب پذیری کشف شده.
- ارائه آدرس و مشخصات دقیق آسیب پذیری کشف شده.
- شرکت موظف است در صورت یافتن ریسک یا آسیب پذیری با درجه اهمیت بحرانی یا بالا، بلافاصله گزارش مربوطه را به همراه راهکار رفع آسیب پذیری (راهکار عملیاتی و قابل پیاده سازی با توضیحات کامل) به صورت مکتوب به بانک ارائه داده و همچنین به صورت تلفنی نیز مراتب را اطلاع دهد. ارائه این گزارش رافع مسئولیت شرکت در ارائه گزارش کامل تست نفوذ نمی باشد.
- توضیح در خصوص علت و شرح مفهوم هر یک از آسیب پذیری های کشف شده.
- محاسبه درجه اهمیت هر یک از آسیب پذیری های کشف شده بر اساس استاندارد CVSS V3 (شامل ریسک با درجه اهمیت بحرانی، بالا، متوسط، پایین و اطلاعاتی)
- ۴-۲۴) شرکت متعهد و مکلف گردید کلیه خروجی ها و گزارشات مربوط به ابزارهای مورد استفاده در خصوص موضوع قرارداد را علاوه بر توضیحات و تفاسیر مندرج در بند ۱۱ ماده ۴ به صورت مجزا و به عنوان ضمیمه به بانک ارائه نماید .
- ۴-۲۵) شرکت متعهد و مکلف گردید در هر مرحله با تهیه نمودارها و اشکال مختلف نتایج کمی بررسیهای بعمل آمده را مشخص نماید
- ۴-۲۶) شرکت متعهد و مکلف گردید در حین انجام عملیات قرارداد ، اختلالی در کار کاربران سایت و بانک (به جز در زمانهای خاص و به صورت از قبل تعیین شده طبق هماهنگی با ناظر و مدیریت پروژه) صورت نپذیرد.
- ۴-۲۷) شرکت متعهد و مکلف گردید در پایان هر ماه نسبت به ارسال گزارش کلی از وضعیت آزمون های صورت پذیرفته شامل موارد ذیل اقدام نماید:


شرکت امن افزار گستر شریف

ردیف	نام سامانه	آدرس دسترسی	آزمون نفوذ	ممیزی ۱	ممیزی ۲	ممیزی ۳	ممیزی ۴	...
			وضعیت آسیب پذیری تاریخ	وضعیت آسیب پذیری تاریخ	وضعیت آسیب پذیری تاریخ	وضعیت آسیب پذیری تاریخ	وضعیت آسیب پذیری تاریخ	

۴-۲۸) شرکت متعهد و مکلف گردید کلیه تعهدات مندرج در قرارداد را سوا و انحصاراً توسط فرد یا افراد معرفی شده از طرف شرکت صورت پذیرد و در تمامی مراحل قرارداد از بکارگیری افراد دیگر و یاشرکتهای همکار جداً خودداری نماید .

۴-۲۹) کلیه عوارض و کسورات قانونی متعلق به موضوع این قرارداد برعهده شرکت می باشد .

۴-۳۰) افزایش یا کاهش قیمتها هیچ تاثیری در اجرای تعهدات شرکت نخواهد داشت .

۴-۳۱) شرکت متعهد و مکلف گردید مشکلات و مخاطرات موجود را با بهره گیری از کامل ترین و بهترین نرم افزارهای رایگان و غیر رایگان و همچنین دانش و مهارت فرد متخصص معرفی شده ، دقیقاً بررسی نموده و در صورت عدم تائید ناظر و مدیر پروژه در خصوص انجام تعهدات یا دستیابی موفقیت آمیز به اهداف تعیین شده ، کلیه وجوه دریافتی را به بانک مسترد و حق هرگونه مطالبه مبلغ ، ایراد و اعتراضی را در این خصوص از خود سلب و ساقط نماید .

۴-۳۲) شرکت موظف به برگزاری دوره آموزش CEH V۱۱ به صورت رایگان به مدت حداقل ۴۰ ساعت در محل شرکت و یا به صورت مجازی (طبق صلاحدید بانک) با ارایه مدرک رسمی طی دوره مذکور ، برای ۱۰ نفر از کارشناسان اداره کل انفورماتیک میباشد .

۴-۳۳) شرکت متعهد گردید در صورت درخواست بانک ، اطلاعات کارمندان و تضامین اخذ شده از آنان را طی لیستی به بانک اعلام نماید.

۴-۳۴) شرکت موظف است در پایان قرارداد کلیه مستندات مربوط به موضوع قرارداد را که در اختیار دارد به بانک تحویل دهد و ضمن حفظ اسناد و مدارک اخذ شده از بانک، آنها را محرمانه تلقی نموده و پس از اتمام موضوع قرارداد آنها را به بانک عودت دهدو هیچ نسخه ای از اطلاعات را به هر صورت نزد خود نگهداری نکند.

۴-۳۵) شرکت متعهد و مکلف گردید همزمان با ارسال اولین صورتحساب خود ، فهرست افراد و پرسنل درگیر با پروژه را به بانک اعلام نماید.

تعهدات امنیتی

۴-۳۶) شرکت متعهد و مکلف گردید بندهای امنیتی قرارداد را در تمامی مراحل تولید سامانه اطلاعاتی رعایت و اجرا نموده و نتایج و مستندات مربوط به اجرای آنها را به بانک ارائه نماید.

شرکت امن افزار گستر شریف

مراجعه به کارشناسان اداره کل انفورماتیک

تاریخ

۱۴۰۱/۰۶/۲۰

تبصره ۳: اجرای بندهای امنیتی باید در جلسات منظم که زمانبندی آنها توسط طرفین مورد توافق قرار می گیرد مورد بررسی قرار گرفته و توافقات حاصل در جلسات پس از تایید بانک لازم الاجرا می باشند. تدوین صورتجلسه به عهده پیمانکار است.

۴-۳۷) شرکت متعهد و مکلف گردید در صورتی که در حین اجرای قرارداد، بخشنامه ها یا دستورالعمل های امنیتی جدیدی از سوی کارفرما و یا مراجع بالا دستی ابلاغ گردید آنها را در تمامی مراحل تولید سامانه اطلاعاتی رعایت و اجرایی نماید.

۴-۳۸) شرکت متعهد و مکلف گردید الزامات مربوطه که در استاندارد ISO/IEC ۱۵۴۰ ذکر شده است را در تمامی مراحل تولید سامانه اطلاعاتی رعایت و اجرا نموده و قبل از پیاده سازی و اجرای نهایی سامانه اطلاعاتی، نسبت به دریافت گواهی ارزیابی امنیتی برای سامانه اطلاعاتی اقدام نموده و اصل گواهی ارزیابی امنیتی سامانه اطلاعاتی را به کارفرما تحویل نماید.

تبصره ۴: ارزیابی امنیتی سامانه اطلاعاتی باید توسط شرکت های معرفی شده و مورد تایید مرکز مدیریت راهبردی افتا صورت پذیرفته و شرکت موظف است قبل از اقدام برای انجام ارزیابی امنیتی، تاییدیه های لازم را از بانک دریافت نماید.

تبصره ۵: شرکت متعهد و مکلف گردید تمامی مستندات و نتایج مربوط به ارزیابی امنیتی را به بانک تحویل نموده است و در صورتی که در ارزیابی، وجود هر گونه نقص و آسیب پذیری امنیتی در سامانه اطلاعاتی مشخص گردید، شرکت موظف است ضمن رفع تمامی نقص ها و آسیب پذیری، علت ایجاد آنها، روش های برطرف سازی آنها و روش استفاده شده برای برطرف سازی را به بانک اقدام نماید.

تبصره ۶: ارزیابی امنیتی تا زمان دریافت گواهی امنیتی سامانه اطلاعاتی باید تکرار گردد و شرکت موظف است قبل از هر تکرار تاییدیه های لازم را از بانک دریافت نموده و تمامی مستندات هر ارزیابی امنیتی را به کارفرما تحویل نماید.

۴-۳۹) شرکت متعهد گردید در صورت درخواست بانک، اطلاعات کارمندان و تضامین اخذ شده از آنان را طی لیستی به بانک (اداره کل انفورماتیک) اعلام نماید.

۴-۴۰) شرکت متعهد و مکلف گردید همزمان با ارسال اولین صورتحساب فهرست افراد و پرسنل مرتبط با پروژه را به بانک (اداره کل انفورماتیک) اعلام نماید.

۴-۴۱) شرکت متعهد و مکلف گردید در صورتیکه کارکنان زیرمجموعه مرتبط با فعالیتهای بانک صادرات ایران به انحاء مختلف، قطع همکاری نمایند، به قید فوریت، مشخصات فرد یا افراد مذکور را به اداره کل انفورماتیک اعلام تا اداره کل یاد شده آگاهی رسانی لازم را در سطح شبکه بانک معمول نماید.

۴-۴۲) شرکت متعهد و مکلف گردید با عنایت به اهمیت حفاظت از اطلاعات بانک به نمایندگی از سوی بانک، تعهدنامه منع افشای اطلاعات (پیوست ۲ و ۳ این قرارداد) را از تک تک پرسنل خود که به طریقی با این قرارداد مرتبط می باشند یا در آینده مرتبط می گردند (شامل کارکنان، مشاوران و مدیران)؛ اخذ نموده و در پرونده کارکنان شرکت درج و در صورت درخواست بانک اصل یا تصویر آن را به بانک ارائه نماید.

۴-۴۳) شرکت متعهد و مکلف گردید در صورت درخواست کتبی بانک نسبت به افزایش یا کاهش حداکثر به میزان ۲۵٪ موضوع قرارداد در طول مدت قرارداد و براساس قیمت و شرایط مندرج در قرارداد نسبت به ارائه خدمات و پشتیبانی با توافق طرفین اقدام نماید.

شرکت امن افزار گستر شریف

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

۴-۴۴) شرکت متعهد و مکلف گردید در صورت درخواست های ضروری و فوری بانک حسب نظر اداره کل انفورماتیک که توسط شرکت انجام می پذیرد با ضریب مبلغ ۱/۵ برابر نسبت به سایر درخواستهای عادی با رعایت سقف مبلغ قرارداد .
۴-۴۵) شرکت متعهد و مکلف گردید در صورتی که در حین اجرای قرارداد ، بخشنامه ها یا دستورالعمل های امنیتی جدیدی از سوی کارفرما و یا مراجع بالا دستی ابلاغ گردید آنها را در تمامی مراحل انجام کار رعایت و اجرایی نماید.
۴-۴۶) شرکت متعهد و مکلف گردید در صورت درخواست بانک پس از پایان مدت قرارداد نسبت به ارایه خدمات پشتیبانی و نگهداری بابت موضوع این قرارداد حداقل برای مدت ۳ ماه دیگر تا تعیین پیمانکار با هزینه توافقی اقدام نماید.

ماده ۵- تعهدات بانک

۵-۱) بانک متعهد و مکلف گردید یک نفر به عنوان مدیر پروژه و یک نفر به عنوان ناظر را به شرکت معرفی تا در تمامی مراحل اجرای پروژه، با فرد معرفی شده از سوی شرکت ارتباط داشته باشند.
۵-۲) بانک متعهد و مکلف گردید پس از ارائه صورتحساب رسمی شرکت و تأیید خدمات انجام شده توسط اداره کل انفورماتیک و پس از کسر کلیه عوارض و کسورات قانونی ، مبالغ مطروحه را در وجه شرکت کارسازی نماید.

ماده ۶- تضمینات و وثایق

شرکت متعهد و مکلف گردید همزمان با انعقاد قرارداد ، نسبت به ارائه ضمانتنامه بانکی (غیر از بانک صادرات ایران) یا چک بانکی بانک صادرات ایران به میزان ۱۰٪ کل مبلغ قرارداد بابت حسن اجرای قرارداد و انجام تعهدات اقدام نماید.
تبصره ۱: بدیهی است تضمین ارائه شده از سوی شرکت پس از اتمام کامل قرارداد و در صورت رضایت بانک به شرکت مسترد خواهد شد.

ماده ۷- نحوه فسخ قرارداد

۷-۱) چنانچه شرکت از اجرای هر یک از تعهدات خود به شرح ماده (۴) این قرارداد تخلف ورزیده و یا خودداری نماید و یا حسب تشخیص کارشناس، طرفین شرکت، توانایی فنی و مالی کافی برای انجام موضوع قرارداد را انجام نداده باشند و یا فرد متخصص مشخص شده جهت اجرای صحیح موضوع قرارداد را بکار نگمارد ، بانک حق فسخ یکجانبه قرارداد را خواهد داشت . تشخیص بانک برای تحقق شرایط فسخ قرارداد کافی می باشد و در صورت فسخ ، کلیه مطالبات و تضمینات شرکت نزد بانک ، به نفع بانک ضبط و وصول خواهد شد و شرکت ضمن عقد خارج لازم حق فسخ یکجانبه قرارداد را از خود سلب می نماید.

ماده ۸- خسارت تاخیر

در صورت تاخیر در ارائه موضوع قرارداد جریمه ای معادل ۲,۰۰۰,۰۰۰ ریال از صورتحسابهای ارسالی شرکت به ازای هرساعت تاخیر کسر خواهد شد. همچنین بانک حق دارد وجه متعلقه به ایام تاخیر را از باقیمانده مورد معامله کسر نماید. وصول وجوه مذکور به هیچ وجه مانع از مراجعه بانک به مراجع قضایی به منظور الزام شرکت به اجرای تعهداتش نخواهد بود.

شرکت امن افزار گستر شریف

Page ۱۰ of ۲
شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

اداره کل انفورماتیک: تهران، خیابان سپهر، ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



مراجعه به کارشناس صورت تایید می باشد. امضا

ماده ۹۵ - نحوه رفع اختلاف

هر گاه در تفسیر یا اجرای این قرارداد اختلافی بروز کند، طرفین سعی می کنند موضوع را با تشکیل جلسات مسالمت آمیز حل و فصل نمایند. در غیر این صورت، موضوع به هیأت کارشناسی مرکب از نمایندگان طرفین و حکم مرضی الطرفین محول می گردد. در صورت عدم قبول رأی هیأت مذکور، موضوع به شورای انتظامی سازمان نظام صنفی رایانه ای کشور یا محاکم قضایی، ارجاع خواهد شد.

ماده ۱۰ - کسورات قانونی

کلیه کسورات و عوارض قانونی از جمله بیمه ، مالیات و غیره بعهده فروشنده (شرکت) بوده و خریدار (بانک) حق و اختیار دارد کسورات مذکور را از صورتحسابهای ارسالی کسر و نام شرکت به مراجع مربوطه پرداخت نماید.

۱) از هر پرداخت ۱۰٪ بابت حسن انجام کار شرکت توسط بانک کسر و در حسابی نزد بانک نگهداری میشود که در پایان قرارداد به میزان رضایت و تأیید بانک به شرکت مسترد میگردد و در صورت درخواست پیمانکار و موافقت بانک ، حسن انجام کار کسر شده در هر مرحله از قرارداد در قبال تضامین مورد قبول بانک (شامل ضمانتنامه بانکی ، اوراق مشارکت و وثیقه ملکی) به پیمانکار بازگردانده میشود.

۲) از هر پرداخت ۵٪ بعنوان بیمه تامین اجتماعی کسر و تا پایان مدت قرارداد نگهداری و پس از اتمام مدت و در صورت ارائه مقاصداً حساب از سوی شرکت نسبت به عودت مبلغ اقدام خواهد شد.

تصویر ۱۵: کسورات بیمه تامین اجتماعی فقط از محل هزینه های نصب و راه اندازی و سایر هزینه های پرداختی به شرکت کسر میگردد.

ماده ۱۱- قوه قهریه

در صورت بروز هرگونه تأخیر در انجام هر یک از تعهدات طرفین این قرارداد که به سبب عواملی از قبیل سیل ، زلزله ، آتش سوزی و سایر بلایای طبیعی ، جنگ ، قوانین و مقررات حکومتی و شرایط بین المللی و اعتصابات عمومی و ... که در حیطه اختیار و کنترل طرفین قرار ندارد تا زمانی که این علل موجود بوده و ادامه داشته باشند از انجام تعهداتی که به دلایل فوق قابل اجرا نباشند معاف خواهند بود . اما آن بخش از شرایط و مفاد این قرارداد که تحت تاثیر شرایط تعذر قرار نگرفته اند کاملاً نافذ باقی می ماندند و انجام تعهدات مربوط به آنها الزامی خواهد بود.

ماده ۱۲: اقامتگاه طرفین

بانک صادرات ایران - اداره کل تدارکات:

نشانی: تهران - خیابان سمیه - نبش ملک الشعراى بهار - ساختمان برج سپهر - شماره ۸۵ - طبقه ۴.
تلفن: ۸۸۸۳۵۹۱۴-۸۸۳۱۵۸۵۲ شماره نمابر: ۴۱۴۷۶۲۰۱
کدپستی: ۱۵۷۱۸۳۸۷۱۳ صندوق پستی: ۱۵۸۷۵/۷۷۷۳

شرکت امن افزار گستر شریف

Page 11 of 30

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

در آكل كافيور ان، خيابان سميّه، ساختمان سپهر، شماره ۸۵ كديستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک

بانک صادرات ایران
اداره کارگزاری

عزیز میر کا طرز فی مورد تائید ہے۔ اچھا

تاریخ: ۱۴۰۱/۰۶/۲۰
شماره: ۱۴۰۱/۶۸۲۵۲۵
پیوست:

باسمه تعالی



قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

اداره کل انفورماتیک :

نشانی : خیابان سمیه - تقاطع ملک الشعراء بهار (رو به روی ضلع غربی برج سپهر) ساختمان برج غدیر - پلاک ۸۷

تلفن : ۸۴۷۶۵۰۱۰

شماره نمابر : ۹۱۰۸۶۵۰۹

کد پستی : ۱۵۷۱۸۱۲۳۴۵

شرکت امن افزار گستر شریف:

نشانی : میدان ونک ، خیابان خدای ، پلاک ۱۰۰ ، طبقه پنجم .

تلفن : ۰۲۱-۴۳۶۵۲۰۰۰

شماره نمابر : ۰۲۱-۸۸۲۱۷۳۸۵

کدپستی : ۱۹۹۴۸۱۶۴۱۳

صندوق پستی : _____

اقامتگاه طرفین از حیث ارسال و ابلاغ مکاتبات و اوراق قضایی به شرح فوق می باشد مادامیکه تغییر نشانی کتباً به طرف مقابل اعلام نشده باشد نشانی قبلی ملاک عمل خواهد بود.

ماده ۱۳- نسخ قرارداد

این قرارداد در ۱۳ ماده و در ۳ نسخه ۳۰ صفحه ای با اعتبار یکسان تنظیم و بین طرفین امضاء مبادله گردید.

شرکت امن افزار گستر شریف
(سهامی خاص)

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک

شرکت امن افزار گستر شریف

Page ۱۲ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

اداره کل انفورماتیک - اداره کل تدارکات - بانک صادرات ایران
ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir



موراجع به بانک ملی صورت گیرد می باشد

مهر

تاریخ: ۱۴۰۱/۰۶/۲۰

شماره: ۱۴۰۱/۶۸۲۵۲۵

پیوست:

باسمه تعالی

قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)



ضمیمه یک

زمانبندی انجام تست نفوذ

سطح	زمان اجرا (به روز)
۱	۲۰
۲	۱۵

مورالین به کارگرفتن صورت پذیرفته است.

شرکت امن افزار گستر شریف

Page ۱۳ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴
کد ملی: ۱۵۷۱۸۲۸۷۱۴

اداره کل انفورماتیک

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



۵۰۰

ضمیمه دو

لیست موارد آزمون سطح ۱ برنامه های کاربردی وب

شماره	کلاس	مورد آزمون
۱	جمع آوری اطلاعات	عملیات انگشتنگاری
۲		شناسایی پورت های باز کارپذیر
۳	تنظیمات و پیکره بندی	پیاپی سازی سازوکار HSTS
۴		برشماری واسطه های مدیریتی
۵		بررسی فایل های پشتیبان، قدیمی و بدون مرجع
۶		نمایش محتوای پوشه ها
۷	مدیریت هویت کاربران	برشماری کاربران
۸		بررسی فرایند ثبت نام
۹	احراز هویت	بررسی فرایند ورود به حساب کاربری
۱۰		بررسی فرایند تغییر و بازنشانی گذرواژه
۱۱		سیاست های مناسب برای انتخاب گذرواژه
۱۲		صحت پیاده سازی سازوکار مسدودسازی
۱۳		صحت پیاده سازی کد کپچا
۱۴	مجاز شماری	ارجاع ناامن کاربر به یک موجودیت
۱۵		پیمایش مسیر پوشه ها و پرونده های آن
۱۶		بررسی مجوز کاربران
۱۷	مدیریت نشست	تنظیمات نشست
۱۸		امکان تعیین نشست توسط کاربر
۱۹		حمله جعل درخواست
۲۰		بررسی روند خروج از برنامه
۲۱	اعتبارسنجی ورودی	آزمون تزریق HTML
۲۲		آزمون XSS
۲۳		آزمون تزریق SQL
۲۴		مجموعه آسیب پذیری های تزریق
۲۵		اجرای دستورات سیستم عاملی از راه دور

شرکت امن افزار گستر شریف

Page ۱۴ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک



۱۵۷۱۸۳۸۷۱۳ کدپستی شماره ۸۵ ساختمان سپهر، خیابان سمیه،

مراجعه به کارشناسان مرکز انفورماتیک

تاریخ: ۱۴۰۱/۰۶/۲۰

شماره: ۱۴۰۱/۶۸۲۵۲۵

پیوست:

باسمه تعالی



قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

مدیریت مناسب خطاها	۲۶	مدیریت خطاها و استثنائات
مدیریت مناسب استثنائات	۲۷	
ارسال اطلاعات از طریق کانال رمزگذاری شده	۲۸	رمزنگاری ضعیف
صحت پیاده سازی SSL/TLS	۲۹	
ارسال کلمه عبور به صورت متن آشکار	۳۰	
ذخیره سازی گذرواژه به صورت غیرقابل بازگشت	۳۱	
استفاده از مقادیر تصادفی مناسب	۳۲	
به اشتراک گذاری منابع با منشأ مختلف	۳۳	آسیب پذیری های سمت کاربر
آسیب پذیری سرقت کلیک	۳۴	
ذخیره داده های حساس سمت کاربر	۳۵	
بررسی بارگذاری امن فایل دلخواه	۳۶	آسیب پذیری های منطقی
اجرا بعد از هدایت مجدد	۳۷	
منع خدمت منطقی	۳۸	منع خدمت
منع خدمت لایه برنامه کاربردی	۳۹	

مهر تایید بر کافین صورت تایید می باشد - ۱۳۹۹

شرکت امن افزار گستر شریف

Page ۱۰ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

اطلاعات ممکن است قوایم امنیتی را نقض کند. شماره ۸۵ کد پستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



مهر تایید

الف ۲۰ - ۰۰۸۰۰۰۵۰۰۵ ب ۷۶ ج ۱

لیست موارد آزمون سطح ۱ برنامه‌های کاربردی موبایل نسخه IOS

مورد آزمون	کلاس	
عملیات انگشتنگاری	جمع‌آوری اطلاعات	۱
مدیریت مناسب خطاها و استثنائات		۲
نشت اطلاعات از طریق IPC	نشت اطلاعات	۴
نشت اطلاعات کاربران به واسطه سوم		۵
بررسی لاگ‌های برنامه در سیستم		۶
بررسی محتوای حافظه رم		۷
ثبت Snapshot از اطلاعات حساس		۸
نشت اطلاعات در نسخه‌های پشتیبان		۹
نشت اطلاعات از طریق باینری برنامه		۱۰
ذخیره‌سازی در Keychain و کلاس مدیریت دسترسی	نحوه ذخیره‌سازی اطلاعات	۱۱
بررسی محتوای Cookie Store		۱۲
ذخیره اطلاعات حساس سمت کاربر		۱۳
پرچم‌های امنیتی و کیفیت کد	پیکره‌بندی امن برنامه	۱۴
ردیابی پویای برنامه کاربردی		۱۵
وجود آسیب‌پذیری در Webview برنامه		۱۶
تزریق SQL سمت کاربر		۱۷
ارسال اطلاعات از طریق کانال رمزگذاری شده	کانال ارتباطی و الزامات رمزنگاری	۱۸
پیاده‌سازی سازوکار Certificate Pinning		۱۹
کیفیت رمزنگاری اطلاعات		۲۰
سازوکار تشخیص Jailbreak	وجود سازوکارهای امنیتی	۲۱
استفاده از سازوکار مبهم‌سازی		۲۲
صحت‌سنجی اطلاعات ذخیره شده سمت کاربر		۲۳
مدیریت امن Dictionary و Clipboard		۲۴
تشخیص نسخه برنامه توسط کاربر		۲۵
تغییر برنامه در Runtime و مدیریت کنترلرها		۲۶

Page 16 of 30

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

سمیه، ساختمان سیهر، شماره ۸۵ کدیستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک

بانک صادرات ایران
اداره کل تدارکات

میرزا محمد علی

تشخیص Repackaging و Binary Patching	۲۷
صحت پیاده سازی SSL/TLS	۲۸
دور زدن سازوکار تشخیص Jailbreak	۲۹
دور زدن سازوکار Certificate Pinning	۳۰
آسیب پذیری در سازوکار رمزنگاری اطلاعات	۳۱
سازوکار احراز هویت سمت کاربر	۳۲
مدیریت فرایند ثبت نام	۳۳
بررسی فرایند ورود به حساب کاربری	۳۴
بررسی فرایند تغییر و بازنشانی گذرواژه	۳۵
سیاست های مناسب برای انتخاب گذرواژه	۳۶
تنظیمات شناسه احراز هویت کاربران و فرآیند خروج	۳۷
آسیب پذیری TouchID	۳۸
مجموعه حملات تزریق	۳۹
بارگذاری امن فایل دلخواه	۴۰
نمایش محتوای پوشه ها	۴۱
عدم بررسی سیاست های امنیتی توسط کاربرپذیر	۴۲
منع خدمت منطقی	۴۳
منع خدمت لایه برنامه کاربردی	۴۴
برشماری کاربران	۴۶
امکان ارتقای سطح دسترسی کاربران	۴۷
اجرای امور سایر کاربران با سطح دسترسی یکسان	۴۸
آسیب پذیری در Custom URL و URL Handler	۴۹
صحت عملکرد راهکار جلوگیری از جست و جوی فراگیر	۵۰

مهرات بر کلمات فوقی مورد تایید می باشد. امضا

شرکت امن افزار گستر شریف

لیست موارد آزمون سطح ۱ برنامه های کاربردی موبایل نسخه اندروید

شماره	کلاس	مورد آزمون
۱	جمع آوری اطلاعات	عملیات انگشت نگاری
۲		مدیریت مناسب خطاها و استثنائات
۳	نشت اطلاعات	نشت اطلاعات کاربران به واسطه سوم
۴		بررسی لاگ های برنامه در سیستم
۵		ثبت ScreenShot از اطلاعات حساس
۶		نشت اطلاعات در نسخه های پشتیبان
۷	نحوه ذخیره سازی اطلاعات	ذخیره اطلاعات حساس سمت کاربر
۸		کیفیت رمزنگاری مقادیر ذخیره شده
۹	پیکره بندی امن بستر برنامه	ردیابی پویای برنامه کاربردی
۱۰		بررسی مجوزهای داده شده به برنامه
۱۱		بررسی امضای برنامه کاربردی
۱۲		کیفیت تولید مقادیر تصادفی
۱۳	کانال ارتباطی و الزامات رمزنگاری	ارسال اطلاعات از طریق کانال رمزگذاری شده
۱۴		پیاده سازی سازوکار Certificate Pinning
۱۵	وجود سازوکارهای امنیتی	سازوکار تشخیص Root
۱۶		سازوکار تشخیص شبیه سازی های اندروید
۱۷		استفاده از سازوکار مبهم سازی
۱۸		جامعیت اطلاعات ذخیره شده سمت کاربر
۱۹		مدیریت امن Dictionary و Clipboard
۲۰		تشخیص نسخه برنامه توسط کاربر
۲۱		جلوگیری از دستکاری برنامه اندرویدی
۲۲	کیفیت پیاده سازی سازوکارهای امنیتی	صحت پیاده سازی SSL/TLS
۲۳		دور زدن سازوکار تشخیص Root
۲۴		دور زدن سازوکار Certificate Pinning
۲۵		آسیب پذیری در سازوکار رمزنگاری اطلاعات
۲۶	اصالت سنجی و احراز هویت	مدیریت فرایند ثبت نام
۲۷		بررسی فرایند ورود به حساب کاربری
۲۸		بررسی فرایند احراز هویت از طریق اثر انگشت
۲۹		بررسی فرایند تغییر و بازنشانی گذرواژه

شرکت امن افزار گستر شریف

Page ۱۸ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

ادارات مرکزی: تهران، خیابان جمهوری، ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



موردی به لحاظ فنی مورد تأیید می باشد. انچه

تست نفوذ

سیاست های مناسب برای انتخاب گذرواژه	۳۰
تنظیمات شناسه احراز هویت کاربران و فرآیند خروج	۳۱
سازوکار احراز هویت سمت کاربر	۳۲
مجموعه حملات تزریق	۳۳
عدم بررسی سیاست های امنیتی توسط کاربرپذیر	۳۴
منع خدمت منطقی	۳۵
منع خدمت لایه برنامه کاربردی	۳۶
بر شماری کاربران	۳۷
امکان ارتقای سطح دسترسی کاربران	۳۸
اجرای امور سایر کاربران با سطح دسترسی یکسان	۳۹
صحت عملکرد راهکار جلوگیری از جستجوی فراگیر	۴۰

مراجعه به کلیه فکتی مورد تأیید می باشد. ۱۴۰۱

شرکت امن افزار گستر شریف



۱۳۰

مکمل

الف - ۰۲۰۰ - ۵۰۰۰ ب ۷۸ ج ۱

ضمیمه ۳

لیست موارد آزمون سطح ۲ برنامه های کاربردی وب

شماره	کلاس	مورد آزمون
۱	جمع آوری اطلاعات	عملیات انگشتنگاری
۲		شناسایی پورت های باز کارپذیر
۳	تنظیمات و پیکره بندی	برشماری واسط های مدیریتی
۴		بررسی فایل های پشتیبان، قدیمی و بدون مرجع
۵		نمایش محتوای پوشه ها
۶	مدیریت هویت کاربران	برشماری کاربران
۷	احراز هویت	اصالت سنجی ایمن کاربران
۸		سیاست های مناسب برای انتخاب گذرواژه
۹		صحت پیاده سازی سازوکار مسدودسازی
۱۰	مجاز شماری	ارجاع ناامن کاربر به یک موجودیت
۱۱		پیمایش مسیر پوشه ها و پرونده های آن
۱۲		بررسی مجوز کاربران
۱۳	مدیریت نشست	تنظیمات نشست
۱۴		حمله جعل درخواست
۱۵	اعتبار سنجی ورودی	آزمون تزریق HTML
۱۶		آزمون XSS
۱۷		آزمون تزریق SQL
۱۸		مجموعه آسیب پذیری های تزریق
۱۹		اجرای دستورات سیستم عاملی از راه دور
۲۰	مدیریت خطاها و استثنائات	مدیریت مناسب خطاها
۲۱	رمزنگاری ضعیف	ارسال اطلاعات از طریق کانال رمزگذاری شده
۲۲		ذخیره سازی گذرواژه به صورت غیر قابل بازگشت
۲۳		استفاده از مقادیر تصادفی مناسب
۲۴	آسیب پذیری های سمت کاربر	تنظیم مناسب سرآیندهای امنیتی کارپذیر
		ذخیره داده های حساس سمت کاربر

شرکت امن افزار گستر شریف

موراد بنی محمدی موراد بنی محمدی



۱۳۰۰

تاریخ: ۱۴۰۱/۰۶/۲۰
شماره: ۱۴۰۱/۶۸۲۵۲۵
پیوست:

باسمه تعالی



قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

۲۵	آسیب پذیری های	بررسی بارگذاری امن فایل دلخواه
۲۶	منطقی	اجرا بعد از هدایت مجدد
۲۷	منع خدمت	منع خدمت منطقی
۲۸		منع خدمت لایه برنامه کاربردی

مراجعه به گنجینه صورت های مالی بابت ۱۰۰٪

شرکت امن افزار گستر شریف

Page ۲۱ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

سمیه، ساختمان سپهر، شماره ۸۵ کدپستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



فهرست

قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

لیست موارد آزمون سطح ۲ برنامه‌های کاربردی موبایل نسخه IOS

شماره	کلاس	مورد آزمون
۱	جمع‌آوری اطلاعات	عملیات انگشت‌نگاری
۲		مدیریت مناسب خطاها و استثنائات
۳	نشت اطلاعات	نشت اطلاعات کاربران به واسطه سوم
۴		ثبت Snapshot از اطلاعات حساس
۵	نحوه ذخیره‌سازی اطلاعات	نحوه ذخیره‌سازی در Keychain
۶		ذخیره اطلاعات حساس سمت کاربر
۷	کانال ارتباطی و الزامات رمزنگاری	ارسال اطلاعات از طریق کانال رمزگذاری شده
۸		پیاده‌سازی سازوکار Certificate Pinning
۹	وجود سازوکارهای امنیتی	سازوکار تشخیص Jailbreak
۱۰		یکپارچگی اطلاعات ذخیره شده سمت کاربر
۱۱		مدیریت امن Dictionary و Clipboard
۱۲		تشخیص نسخه برنامه توسط کاربرپذیر
۱۳	کیفیت پیاده‌سازی سازوکارهای امنیتی	صحت پیاده‌سازی SSL/TLS
۱۴		دور زدن سازوکار تشخیص Jailbreak
۱۵		دور زدن سازوکار Certificate Pinning
۱۶	اصالت‌سنجی و احراز هویت	سازوکار احراز هویت سمت کاربر
۱۷		مدیریت فرایند ثبت‌نام
۱۸		بررسی فرایند ورود به حساب کاربری
۱۹		بررسی فرایند تغییر و بازنشانی گذرواژه
۲۰		سیاست‌های مناسب برای انتخاب گذرواژه
۲۱		تنظیمات شناسه احراز هویت کاربران و فرایند خروج
۲۲	آسیب‌پذیری‌های سمت کاربرپذیر	مجموعه حملات تزریق
۲۳		عدم بررسی سیاست‌های امنیتی توسط کاربرپذیر
۲۴	منع خدمت	منع خدمت منطقی
۲۵		منع خدمت لایه برنامه کاربردی
۲۶	منطق کسب‌وکار	برشماری کاربران

شرکت امن افزار گستر شریف

Page ٢٢ of ٣٠

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

ساختمان سپهر، شماره ۸۵ کدیستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک

بانی و صادران ایران
اداره کل امور مالیاتی
تهران

بانک صادرات ایران
اداره کل تدارکات

Azizah binti Mohd Yusoff

525

تاریخ: ۱۴۰۱/۰۶/۲۰

شماره: ۱۴۰۱/۶۸۲۵۲۵

پیوست:

باسمه تعالی



قرارداد ارزیابی امنیتی وب سایت های اینترنتی (تست نفوذ)

امکان ارتقای سطح دسترسی کاربران	۲۷
اجرای امور سایر کاربران با سطح دسترسی یکسان	۲۸
صحت عملکرد راهکار جلوگیری از جست و جوی فراگیر	۲۹

مواظب به کارهای صورت گرفته باشید. ان شاء الله

شرکت امن افزار گستر شریف

Page ۲۳ of ۳۰

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

۱۵۷۱۸۳۸۷۱۳ کدپستی شماره ۸۵ ساختمان سپهر، سمیه، تهران

www.bsi.ir

بانک صادرات ایران
اداره کل تدارکات - اداره کل انفورماتیک



م
ر
ف
ن

لیست موارد آزمون سطح ۲ برنامه‌های کاربردی موبایل نسخه اندروید

شماره	کلاس	مورد آزمون
۱	جمع‌آوری اطلاعات	عملیات انگشت‌نگاری
۲		مدیریت مناسب خطاها و استثنائات
۳	نشت اطلاعات	بررسی لاگ‌های برنامه در سیستم
۴		ثبت ScreenShot از اطلاعات حساس
۵	نحوه ذخیره‌سازی اطلاعات	ذخیره اطلاعات حساس سمت کاربر
۶	پیکره‌بندی امن بستر برنامه	ردیابی پویای برنامه کاربردی
۷		بررسی مجوزهای داده شده به برنامه
۸		کیفیت تولید مقادیر تصادفی
۹	کانال ارتباطی و الزامات رمزنگاری	ارسال اطلاعات از طریق کانال رمزگذاری شده
۱۰		پیاده‌سازی سازوکار Certificate Pinning
۱۱	وجود سازوکارهای امنیتی	سازوکار تشخیص Root
۱۲		سازوکار تشخیص شبیه‌سازهای اندروید
۱۳		استفاده از سازوکار مبهم‌سازی
۱۴		تشخیص نسخه برنامه توسط کاربرپذیر
۱۵	کیفیت پیاده‌سازی سازوکارهای امنیتی	صحت پیاده‌سازی SSL/TLS
۱۶		دور زدن سازوکار تشخیص Root
۱۷		دور زدن سازوکار Certificate Pinning
۱۸		آسیب‌پذیری در سازوکار رمزنگاری اطلاعات
۱۹	اصالت‌سنجی و احراز هویت	مدیریت فرایند ثبت‌نام
۲۰		بررسی فرایند ورود به حساب کاربری
۲۱		بررسی فرایند احراز هویت از طریق اثر انگشت
۲۲		بررسی فرایند تغییر و بازنشانی گذرواژه
۲۳		سیاست‌های مناسب برای انتخاب گذرواژه
۲۴		تنظیمات شناسه احراز هویت کاربران و فرایند خروج
۲۵		سازوکار احراز هویت سمت کاربر
۲۶	آسیب‌پذیری‌های سمت کاربرپذیر	عدم بررسی سیاست‌های امنیتی توسط کاربرپذیر
۲۷	منع خدمت	منع خدمت منطقی

شرکت امن افزار گستر شریف

Page ٢٤ of ٣٠

شرکت امن افزار گستر شریف
سهامی خاص
شماره ثبت: ۱۹۱۵۳۴

بانک صادرات ایران

اداره کل تدارکات - اداره کل انفورماتیک

سمیه، ساختمان سپهر، شماره ۸۵ کد پستی ۱۵۷۱۸۳۸۷۱۳

www.bsi.ir

مدرستہ کا کافی طور پر تیار کیا گیا۔

منع خدمت لایه برنامه کاربردی	۲۸
برشماری کاربران	۲۹
صحت عملکرد راهکار جلوگیری از جست و جوی فراگیر	۳۰

مهرات به کارگزاران صورت داده شد. امضا

شرکت امن افزار گستر شریف
 شرکت امن افزار گستر شریف
 سهامی خاص
 شماره ثبت: ۱۹۱۵۳۴
 Page ۲۰ of ۳۰

بانک صادرات ایران
 اداره کل تدارکات - اداره کل انفورماتیک

